



BY AMETECs

SR-08

SmartEPT Session Report — Licence Enforcement and the IIS Incident

Work completed 14 August 2026, across Central, the Admin Server and the Agent

Version 1.0

14 August 2026

Prepared for: Ejaz Hussain, MD

Contents

01 Summary

02 Finding 1 — a paid subscription did not close the client's trial

03 Finding 2 — no way to act on a licence from the client's card

04 Finding 3 — Central could not see how many users a client had

05 Finding 4 — the seat count was a label, not a rule

06 Finding 5 — the client kept working after expiry and grace had passed

07 Review findings caught before delivery

08 The IIS incident — HTTP 405 on every Edit and Save

09 The Agent is six versions out of date

10 Commits

11 What is outstanding

12 What this means for a client

1. Summary

Two separate pieces of work were completed on 14 August 2026, both raised by Altaf.

First, four licence findings reported by Ejaz were fixed. Taken together they had one theme: SmartEPT displayed licence rules but did not enforce them. A client could hold two active licences at once, could add unlimited users on a one-seat licence, and could keep using the system after their licence had expired and its grace period had run out. Central, meanwhile, could not see how many people a client actually had. All four are now closed across both repositories, with seventeen new automated tests.

Second, a new client's installation was failing with HTTP 405 on every Edit and Save. The cause was found and fixed: that client is the first to run SmartEPT on IIS, and IIS enables WebDAV by default, which takes over PUT and DELETE requests before the application sees them. Nothing was wrong with SmartEPT itself.

A third item was investigated and is **not yet resolved**: the Agent that clients download is six versions out of date. The fix is prepared but the build has not been run.

Nothing in this report has been pushed to the live servers. Everything is committed in the local trees and awaits testing, migration and deployment. Section 11 lists exactly what is outstanding.

2. Finding 1 — a paid subscription did not close the client's trial

What Ejaz reported. The Central dashboard showed multiple active licences for the same client, including a trial alongside a subscription. Once the subscription is activated the trial should be deactivated.

Why it happened. Nothing ever closed a trial. Issuing a paid licence simply added a second row, and both keys kept validating. Skill Dunya on the live board showed exactly this.

What was done. A licence now carries a new status, **superseded** — deliberately its own word rather than "expired", because the trial did not run out of time, it was replaced. Whenever a subscription or perpetual licence is issued, renewed or upgraded for a client, every still-active trial of that client is closed automatically and the reason is written to the licence history.

Three routes that could have brought a closed trial back to life were also shut:

- **Extend trial** now only touches trials that are running or have simply expired. It can no longer resurrect one that was closed because the client bought a subscription.
- **Reactivate** is refused by the server while a paid licence is live for that client.

- The screen shows *"closed by paid licence"* in place of a Reactivate button.
- The monthly purge sweep now closes superseded rows out along with the rest.

Existing clients are fixed too. The migration backfills the correction, so clients who already carry a stale active trial — Skill Dunya among them — are corrected the moment the migration is run, not only from now on.

A note on the database column. `licences.status` and `licences.kind` were widened from ENUM to VARCHAR(20) in the same migration. Adding a new value to a MySQL ENUM truncates silently, which has already caused four separate incidents on this project. The SQLite path is handled separately because SQLite enforces the constraint where MySQL did not.

3. Finding 2 — no way to act on a licence from the client's card

What Ejaz reported. There should be an action beside the Status field to Suspend, Revoke or Reactivate a licence, and the Status field itself must stay.

What was done. The Clients and Tenants detail card now carries **Suspend / Reactivate / Revoke** links beside the Status pill. Status remains exactly where it was. Acting on a licence reopens the card so the pill updates in place.

Revoke was also surfaced on the Licences list. The action had been built and wired to the API for some time, but no button ever called it — it was dead code. It is now visible.

4. Finding 3 — Central could not see how many users a client had

What Ejaz reported. Central is not fetching licence usage from client logins, and is not showing the number of users the client has created.

Why it happened. The only usage figure a client console ever reported was storage. Device counts reached Central one at a time, and only when a new PC activated a seat. A client running fourteen people therefore displayed as "0 of 25".

What was done. Every client console now reports its real headcount on its daily licence check-in: active login accounts, active employees and bound devices. Central stores these against the licence with a timestamp, and shows a **Users** column on both the Licences list and the client card, turning red and marked **OVER LIMIT** when the client has exceeded what they bought.

The counts are optional on the wire, so a console running an older build still validates normally — it simply shows a dash until it is updated.

The privacy wall is unchanged. What crosses is three integers and nothing else. No names, no activity, no monitoring data — licence metadata only, exactly as before.

5. Finding 4 — the seat count was a label, not a rule

What Ejaz reported. The Licence tab showed "Device Seats: 2 registered, 1 licensed" while the client was able to add more than one user, effectively unlimited. The licensed device policy was not working.

Why it happened. It had never been enforced anywhere. The only cap in the system lived on Central and applied at the moment a new PC activated a seat — and even that failed open when Central was unreachable, and was skipped entirely for a device that had registered before. User and employee creation had no cap at all.

What was done. A single new service now answers one question for the whole product — is there a free seat? The rule adopted is **one licensed seat equals one monitored person equals one PC**. Employees and employee logins consume seats; administrator, HR and manager logins are operators of the system and remain free.

The check is applied at every point where the count can grow:

Where	What is refused once the seats are full
Add employee	The employee that would exceed the licence
Bulk import	Rows past the licensed count, each with a clear reason; earlier rows still import
Add user	A new employee-role login
Edit user	Promoting a free role to employee, or re-enabling a disabled employee login
Edit employee	Bringing a relieved employee back to active
Restore archived employee	The restore
Register device	A new PC
Rebind device	Re-claiming a seat for a PC

The count is now taken **locally** rather than asking Central. That is deliberate: the Central seat call fails open by design when Central cannot be reached, which meant an offline server could bind machines indefinitely.

Nobody is thrown out. The rule is not retrospective. A client already over their seat count keeps every person and every PC they have — they simply cannot add the next one.

6. Finding 5 — the client kept working after expiry and grace had passed

What Ejaz reported. Even though the licence had expired and the seven-day grace period had also finished, the client could still sign in and use the application.

Why it happened. The licence gate had been placed on the agent data endpoints only. An expired licence stopped the desktop agents uploading, while every human-facing screen carried on working normally. In practice that meant the console never stopped.

What was done. The gate now covers the entire authenticated application, with one deliberate opening so that the situation can always be recovered:

- **Anyone** may still check who they are signed in as, change their password, and sign out.
- **A Company Admin** may additionally reach the Licence screen — to view, enter, validate or import a key — and Help → Troubleshooting.
- **Everything else** is refused, and the console shows a single full-screen licence notice rather than every screen failing separately with its own error.
- **Ordinary staff cannot sign in at all**, and a single sign-on link is not a way around it.

The person who can fix the problem can therefore always get in and fix it, and nobody else can keep working meanwhile.

One decision needs Ejaz's sign-off. On the shared Ametecs cloud, a Super Admin is our own operator account and is exempt from this block — that install's licence row has no key of its own, because each cloud tenant carries its own licence, so blocking on it would lock Ametecs out of the client list. On a client-hosted server, where the install carries its own key, the Super Admin belongs to the client and gets only the rescue routes like any other admin. This is a judgement call made during the session and has not been approved.

The existing safety rails are untouched: enforcement can still be switched off entirely for demonstration and internal installs, and any internal fault inside the licence machinery lets traffic through rather than taking a client's monitoring down.

7. Review findings caught before delivery

The completed work was put through an adversarial review, which found six real defects. All six were fixed in a second commit in each repository.

1. Device **rebind** bypassed the new seat cap entirely — the exact hole the change claimed to close.
2. Creating a login as HR Admin and then **switching its role to Employee** walked around the cap.
3. **Re-enabling a disabled** employee login did the same.
4. **Reactivating a relieved employee**, and **restoring an archived one**, both did the same.
5. **Extend trial** resurrected superseded trials.
6. The **bulk-import cap was dead on arrival** — three variables were missing from a closure, so the check never ran.

The lesson worth keeping: when you add a cap, guard the paths that *change* a record, not only the paths that *create* one. Five of the six defects were update paths.

8. The IIS incident — HTTP 405 on every Edit and Save

What was reported. A newly set-up client could open every screen and create records, but every attempt to save an edit — Branch, Department, Users, Employees — returned HTTP 405, with some 404s alongside.

How it was found. The code was eliminated first: the routes exist correctly, the console sends a genuine request, the HTTPS middleware answers with an error rather than a redirect, the rewrite rules are standard, and no stale route cache ships in the build. That placed the fault before the application. The give-away then appeared in the client's own test output — `C:\inetpub\wwwroot` — showing this is our first client running on **IIS** rather than Laragon.

The cause. IIS ships WebDAV enabled by default. WebDAV registers itself for the PUT and DELETE verbs and answers 405 before the rewrite rules or PHP are ever reached. GET and POST pass through untouched — which is precisely why every page loaded, every Create worked, and only saving an edit failed.

The fix. The shipped `public\web.config` now removes both the WebDAV module and its handler; both are required, as removing only one leaves it active. The trailing-slash redirect was also restricted to GET and HEAD, since a permanent redirect on a save is retried by the browser as a GET and produces the same 405 by a different route. The installation guide gained a "turn WebDAV off" step, the one-line test that proves it, and a warning that the website must point at the `public` subfolder rather than the application root.

The one-line test, for the next time this appears:

```
curl.exe -i -X PUT http://<server>/api/org/branch/1
```

A healthy server answers `401 Unauthenticated`. A 405 with an `Allow:` header is WebDAV answering, not SmartEPT.

9. The Agent is six versions out of date

Investigated during the session, and **not resolved** — it needs a build, which cannot be run from the session environment.

- What clients download today is **version 0.5.0, built 20 July**. It is the newest Agent in Central's downloads folder, and the portal serves the newest file it finds.
- A **0.11.0** build exists from 25 July but was never copied into Central, so no client has ever received it.
- The source is ahead of even that: the meeting-link change from 27 July, the branded-URL fix from 12 August, and further uncommitted work.

Clients installing today are therefore missing break buttons, meetings, session-revoke handling, gate enforcement and the Active/Idle double-counting fix. More immediately, the branded-URL work matters for the client being set up right now: an Agent pointed at a branded `/<slug>` address will not connect without it.

Prepared during the session: the outstanding branded-URL work was committed, and the version was raised to **0.12.0** — it had never been bumped after the July build, so a rebuild would have silently overwritten the existing file. The build itself, and publishing it to the live server, remain to be done.

10. Commits

Repository	Commit	What it contains
Central	<code>11b2d17</code>	Findings 1 to 3 — trial superseded by paid, actions beside Status, seat reporting, the migration and backfill
Central	<code>3ad8a08</code>	Licence hardening tests, and the SQLite path for the widened columns
Central	<code>2cf456c</code>	Review fixes — every route by which a superseded trial could return
Admin Server	<code>9a1854e</code>	Findings 4 and 5 — the seat service, the console-wide gate, seat reporting, the licence notice, nine tests

Repository	Commit	What it contains
Admin Server	436f0ef	Review fixes — the seat-cap bypasses, plus three further tests
Admin Server	5d62cb9	The IIS WebDAV fix and the installation guide
Agent	3383c81	Branded-URL sign-in, and the version raised to 0.12.0

11. What is outstanding

Nothing below has been done. In order:

1. **Restart Laragon** — Stop All, then Start All — in both applications.
2. **Run `migrate.bat` in Central only.** The Admin Server has no new migration. The Central migration also performs the backfill that corrects existing clients' stale trials.
3. **Run `test.bat` in both repositories.** The suites were not run during the session — the environment had no PHP available. This matters more than usual, because the licence gate now touches every route in the application.
4. **Push both repositories.**
5. **Deploy to live:** pull and migrate Central; pull the Admin Server.
6. **Re-check Skill Dunya on the live board.** The stale trial should read as superseded, and the Users column should populate after that console's next daily check-in, or immediately if Validate now is pressed on its Licence screen.
7. **Build and publish Agent 0.12.0**, to the live server as well as locally.
8. **Rebuild the Admin Server package** so it contains the WebDAV fix, and publish it.

Also worth attention

- **The Super Admin exemption in section 6 has not been approved by Ejaz.** It decides whether a client's own top account can keep using SmartEPT after their licence dies.
- **The client's IIS server may be exposing its configuration.** If `http://<server>/ .env` downloads in a browser, the website is pointed at the application root instead of the `public` subfolder, and the database password is readable by anyone. This should be checked before that server goes live.
- **The package build script does not exclude `bootstrap\cache`.** If anyone runs a configuration cache before packaging, development database credentials ship inside the client ZIP. Offered during the session and not yet fixed.
- **Four tests failed on the client's machine** — three concerning unlicensed and unreachable states, one a meeting-mode validation mismatch. They are on the July build and unrelated to

this work. Running the suite on our own machine will show whether they are real.

12. What this means for a client

This section can be shared with a client. Nothing above it should be.

Licensing is now enforced as it was always described. Three things change in practice:

- **Your licence covers a set number of people.** Once every seat is in use, adding another employee, login or PC is refused with a message explaining why and what to do — free a seat by relieving someone you no longer track, or purchase more users. Nobody currently using SmartEPT is affected; only new additions beyond what you hold are stopped.
- **An expired licence now stops the console, not just the desktop agents.** There is a grace period after expiry, and it is shown on your Licence screen well before it matters. When it ends, your Company Admin can still sign in and enter a renewed key at any time — that route is always open by design, so you are never locked out of fixing it.
- **When you move from a trial to a paid subscription, the trial key is closed automatically.** Use the key from your order email. If a device is still pointed at the old trial key, enter the new one on the Licence screen.

If your SmartEPT runs on IIS and you have seen Save fail with an error code 405, that is resolved. Contact Ametecs for the corrected configuration file, or apply the step in the installation guide.

Ametecs India Private Limited, Hyderabad — WhatsApp 90000 98877.